

Phase 3

Identifying Vulnerabilities

Purpose of Phase 3

The main objective of Phase 3 is to describe the tools used to identify, validate, and analyze vulnerabilities discovered during the assessment. This phase focuses on tool selection, configuration, usage methodology, and limitations, rather than exploitation. Screenshots are included as evidence of execution and configuration. All scanning activity was performed in an isolated VirtualBox lab environment using Kali Linux and remained within authorized training scope.

Tool 1

Masscan (Rapid Exposure Identification)

Tool Description

Masscan is a high-performance TCP port scanner designed to rapidly identify exposed services across hosts. While it does not identify vulnerabilities directly, it plays a critical role in vulnerability identification by revealing exposed attack surfaces that may require deeper analysis.

How the Tool Was Used

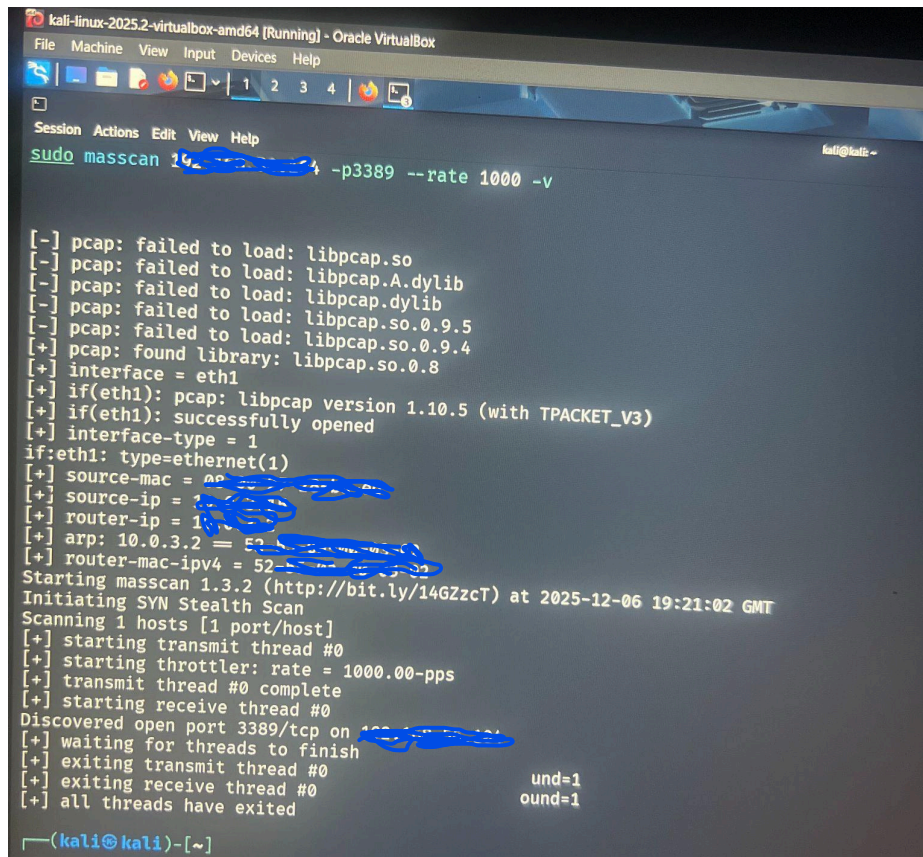
Masscan was executed against the target host to quickly determine whether critical services were exposed. The scan focused on port 3389/tcp, a commonly targeted remote access service.

Command Executed

```
sudo masscan 10.10.10.10 -p3389 --rate 1000 -v
```

The scan confirmed the host was reachable and that port 3389 was open, indicating a potentially exposed Remote Desktop service requiring further assessment.

Figure 3.1 – Masscan confirming open port 3389/tcp on the target host



```
kali-linux-2025.2-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Session Actions Edit View Help
sudo masscan 10.10.10.0/24 -p3389 --rate 1000 -v

[-] pcap: failed to load: libpcap.so
[-] pcap: failed to load: libpcap.A.dylib
[-] pcap: failed to load: libpcap.dylib
[-] pcap: failed to load: libpcap.so.0.9.5
[-] pcap: failed to load: libpcap.so.0.9.4
[+] pcap: found library: libpcap.so.0.8
[+] interface = eth1
[+] if(eth1): pcap: libpcap version 1.10.5 (with TPACKET_V3)
[+] if(eth1): successfully opened
[+] interface-type = 1
if:eth1: type=ethernet(1)
[+] source-mac = 08:00:27:00:00:00
[+] source-ip = 10.10.10.1
[+] router-ip = 10.10.10.1
[+] arp: 10.0.3.2 = 08:00:27:00:00:00
[+] router-mac-ipv4 = 52:54:00:12:34:56
Starting masscan 1.3.2 (http://bit.ly/14GZzcT) at 2025-12-06 19:21:02 GMT
Initiating SYN Stealth Scan
Scanning 1 hosts [1 port/host]
[+] starting transmit thread #0
[+] starting throttler: rate = 1000.00-pps
[+] transmit thread #0 complete
[+] starting receive thread #0
Discovered open port 3389/tcp on 10.10.10.10
[+] waiting for threads to finish
[+] exiting transmit thread #0
[+] exiting receive thread #0
[+] all threads have exited
und=1
ound=1

(kali@kali)-[~]
```

Pros	Cons
Extremely fast enumeration	No service version detection
Ideal for identifying exposed services quickly	No vulnerability identification
Low system overhead	Requires follow-up tools for deeper analysis

Tool 2

Nmap (Service & OS Enumeration)

Tool Description

Nmap is a network exploration and service enumeration tool used to identify open ports, running services, service versions, and operating system fingerprints. It helps determine whether exposed services may be vulnerable based on versioning and configuration.

How the Tool Was Used

Nmap was used after Masscan to collect detailed information about the exposed service. Service detection, default scripts, and OS fingerprinting were enabled to better understand the system's attack surface.

Command Executed

```
sudo nmap -sV -sC -O 10.10.10.10
```

The scan identified:

- Port 3389/tcp open
- Microsoft RDP service
- Windows 10/11 operating system profile
- SSL certificate metadata associated with the service

```
kali-linux-2025.2-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

(kali@kali)-[~]
$ nmap 192.168.56.100
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-06 13:32 EST
Nmap scan report for 192.168.56.100
Host is up (0.016s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
3389/tcp  open  ms-wbt-server
MAC Address: 08:00:27:3E:00:00 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 5.72 seconds

(kali@kali)-[~]
$ nmap -sn -PR 192.168.56.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-06 13:33 EST
Nmap scan report for 192.168.56.100
Host is up (0.0042s latency).
MAC Address: 08:00:27:3E:00:00:0C (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00038s latency).
MAC Address: 08:00:27:3E:00:00:0C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up (0.0019s latency).
MAC Address: 08:00:27:3E:00:00:0C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.24 seconds

(kali@kali)-[~]
$ sudo systemctl enable nessusd
[sudo] password for kali:

(kali@kali)-[~]
$ sudo systemctl start nessusd
```

Figure 3.2 – Nmap service and OS enumeration results for the target host

Pros	Cons
Detailed service and OS identification	Slower than Masscan
Script engine adds contextual security data	OS fingerprinting may return low-confident matches
Widely trusted and documented	Does not assign risk severity

Tool 3

Nessus (Vulnerability Identification & Risk Scoring)

Tool Description

Nessus is an automated vulnerability scanner that identifies known security issues using plugins mapped to CVEs and CVSS scoring. It provides risk ratings and remediation guidance, making it effective for identifying misconfigurations and cryptographic weaknesses.

How the Tool Was Used

A vulnerability scan was executed using Nessus Essentials against the target host. The scan analyzed exposed services and SSL/TLS configurations.

A medium-severity vulnerability was identified:

- SSL Certificate Cannot Be Trusted
- Self-signed certificate
- Broken trust chain
- Same issuer and subject

This issue represents a cryptographic weakness that could facilitate man-in-the-middle attacks if present in production.

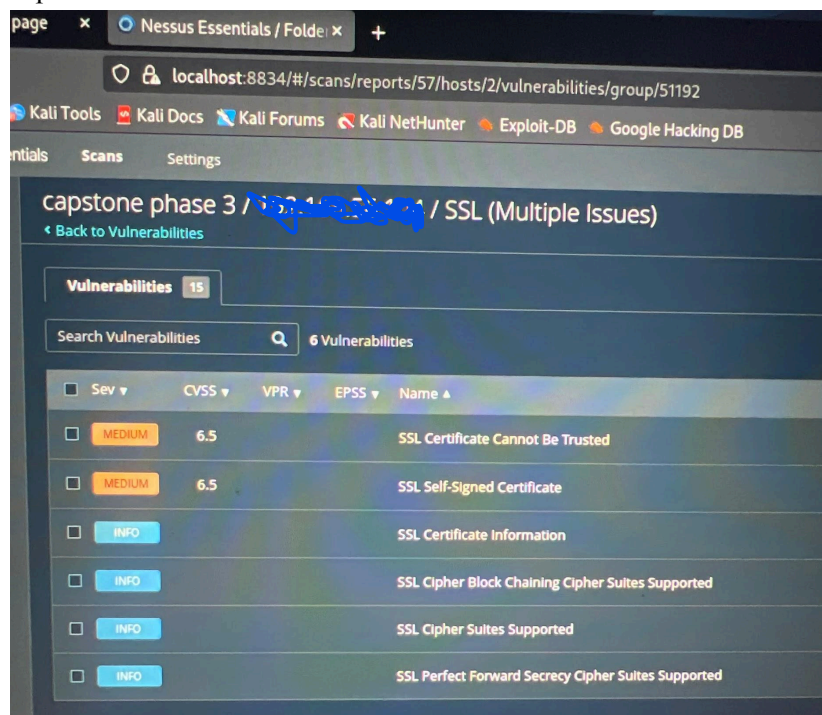


Figure 3.3 – Nessus vulnerability report identifying an untrusted SSL certificate

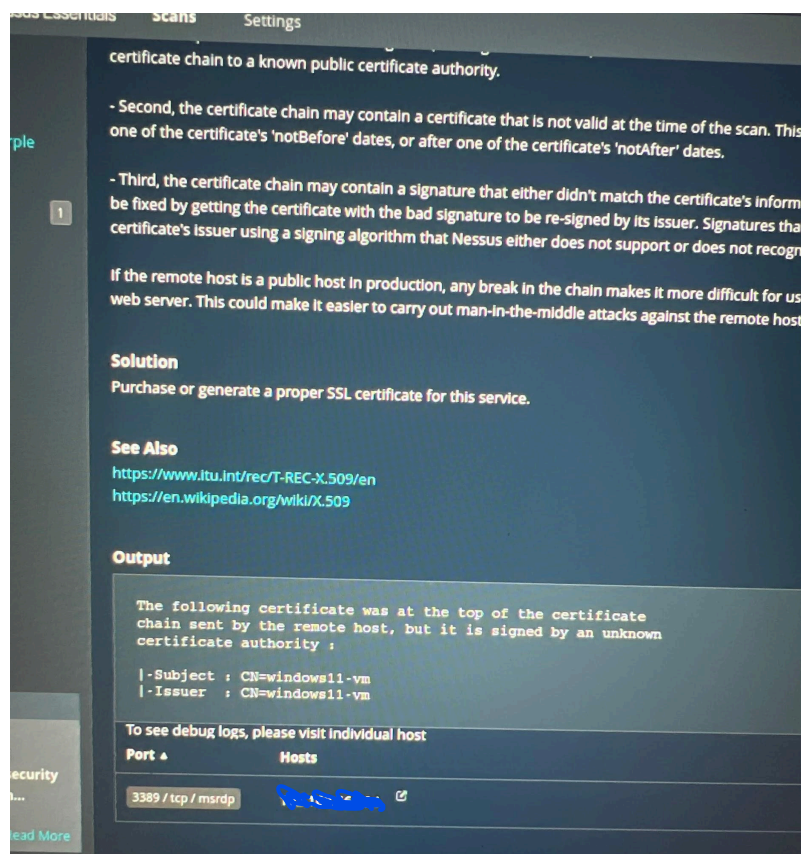


Figure 3.4 – Nessus plugin details and remediation guidance

Pros	Cons
CVSS-based severity scoring	Limited without authenticated credentials
Clear remediation recommendations	Can generate false positives
Industry-recognized vulnerability engine	Requires analyst interpretation

Tool 4

Metasploit (Vulnerability Validation Scanning)

Tool Description

Metasploit is a penetration-testing framework that includes auxiliary scanner modules used to validate service behavior and confirm potential vulnerabilities identified by other tools.

How the Tool Was Used

An auxiliary SSL scanner module was executed to validate the target's SSL response behavior and confirm cryptographic findings identified by Nessus.

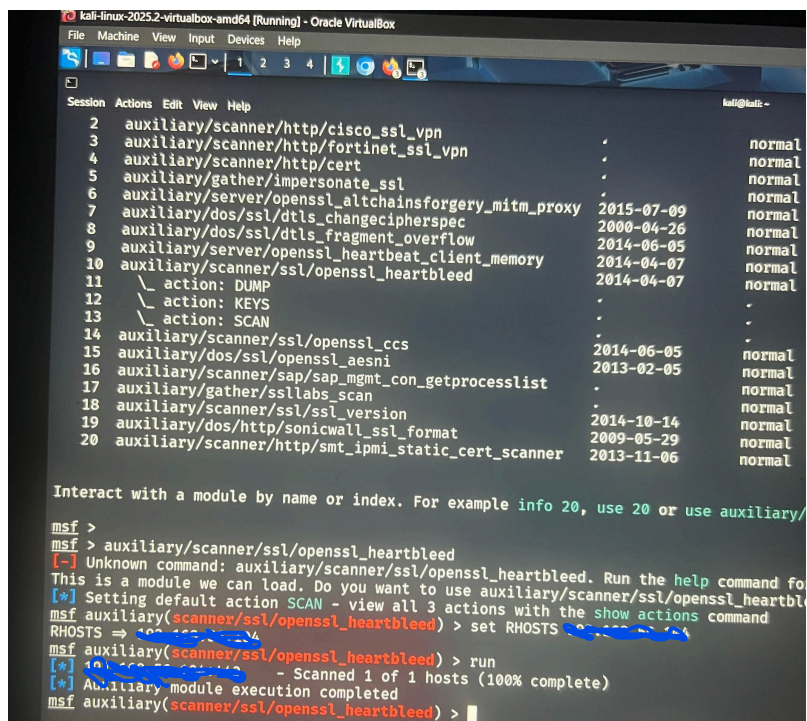
Module Used

auxiliary/scanner/ssl/openssl_heartbeat

Execution

set RHOSTS 192.168.56.104 run

The scan completed successfully and confirmed SSL-level responses from the host without exploitation.



```
kali-linux-2025.2-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

Session Actions Edit View Help
2 auxiliary/scanner/http/cisco_ssl_vpn
3 auxiliary/scanner/http/fortinet_ssl_vpn normal
4 auxiliary/scanner/http/cert normal
5 auxiliary/gather/impersonate_ssl normal
6 auxiliary/server/openssl_altchainsforgery_mitm_proxy normal
7 auxiliary/dos/ssl/dtls_changecipherspec 2015-07-09 normal
8 auxiliary/dos/ssl/dtls_fragment_overflow 2000-04-26 normal
9 auxiliary/server/openssl_heartbeat_client_memory 2014-06-05 normal
10 auxiliary/scanner/ssl/openssl_heartbeat 2014-04-07 normal
11 \ action: DUMP 2014-04-07 normal
12 \ action: KEYS
13 \ action: SCAN
14 auxiliary/scanner/ssl/openssl_ccs 2014-06-05 normal
15 auxiliary/dos/ssl/openssl_aesni 2013-02-05 normal
16 auxiliary/scanner/sap/sap_mgmt_con_getprocesslist normal
17 auxiliary/gather/ssllabs_scan normal
18 auxiliary/scanner/ssl/ssl_version 2014-10-14 normal
19 auxiliary/dos/http/sonicwall_ssl_format 2009-05-29 normal
20 auxiliary/scanner/http/smt_ipmi_static_cert_scanner 2013-11-06 normal

Interact with a module by name or index. For example info 20, use 20 or use auxiliary/
msf >
msf > auxiliary/scanner/ssl/openssl_heartbeat
[-] Unknown command: auxiliary/scanner/ssl/openssl_heartbeat. Run the help command for
This is a module we can load. Do you want to use auxiliary/scanner/ssl/openssl_heartbl
[*] Setting default action SCAN - view all 3 actions with the show actions command
msf auxiliary(scanner/ssl/openssl_heartbeat) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf auxiliary(scanner/ssl/openssl_heartbeat) > run
[*] 192.168.56.104 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssl/openssl_heartbeat) >
```

Figure 3.5 – Metasploit auxiliary SSL scanner execution

Pros	Cons
Validates scanner findings	Requires correct module selection
Non-exploitative at this stage	No automatic risk scoring
Provides protocol-level insight	Not a replacement for vulnerability scanners

Tool 5

Burp Suite (Application-Layer Traffic Analysis)

Tool Description

Burp Suite is a web application security testing platform used to intercept and analyze HTTP/S traffic. It enables analysts to inspect headers, parameters, and application behavior at the application layer.

How the Tool Was Used

Burp Suite was configured as an intercepting proxy between the browser and the target host. Traffic was routed through Burp to confirm visibility into application-layer communication.

Key features used:

- Proxy interception
- HTTP request inspection
- Repeater for request review

Captured traffic confirmed live HTTP communication with the target.

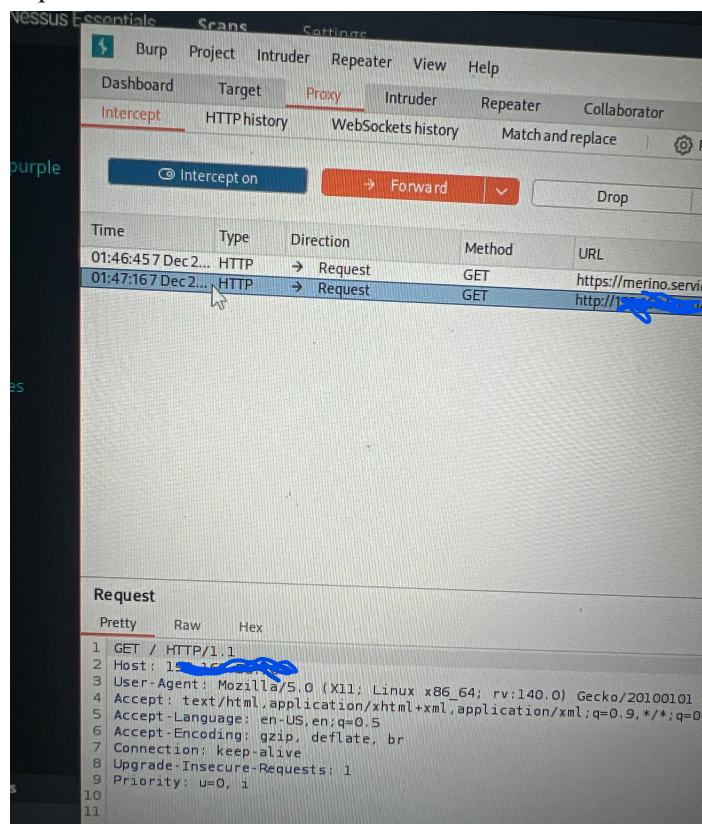


Figure 3.6 – Burp Suite proxy intercepting HTTP requests to the target host

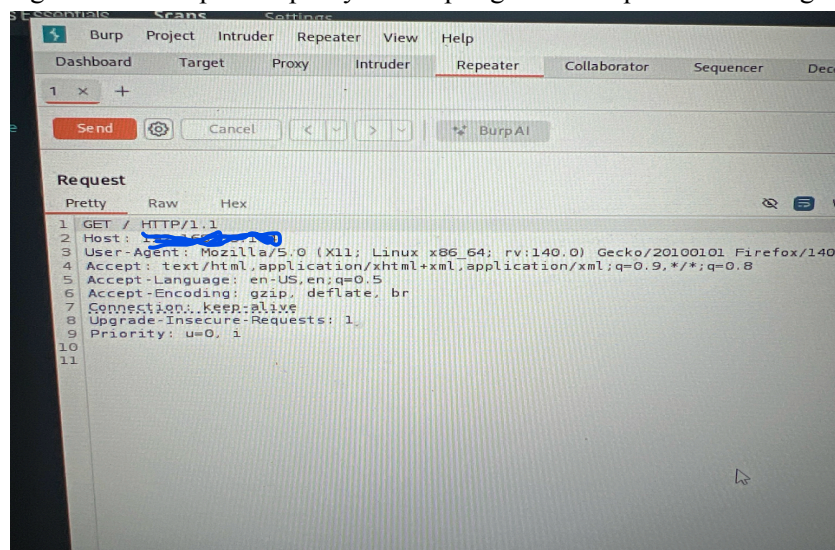


Figure 3.7 – Burp Suite Repeater showing captured request headers

Pros	Cons
Deep visibility into application traffic	Manual configuration required
Effective for manual vulnerability analysis	Community edition has limited automation
Essential for web-layer testing	Dependent on available application endpoints

Phase 3 Conclusion

In summary, Phase 3 demonstrated the use of multiple industry-standard tools to identify and validate vulnerabilities across network, service, cryptographic, and application layers. Each tool served a distinct purpose in the vulnerability identification process, providing layered insight into the system's security posture.